MODULE 02 - RECONNAISSANCE

Assignment 2: Enumerating and Analyzing a Server

Project Athena

Contents

- Objective
- Logistics
- Getting access
- Rules of engagement
- 1. Scanning the Server
- 2. Enumeration
- 3. Analysis
- 4. Report Writing
- Evaluation Criteria
- Bonus: Finding and Exploiting a Vulnerability

Objective

This assignment focuses on server enumeration, a critical part of the reconnaissance phase in cybersecurity. You will spin up your own target server, scan it to find out which services it runs, then *enumerate* those services to pull out the details a port scan alone never shows: shares, files, accounts and device information. For the bonus task, you will identify a vulnerability, exploit it, and document your process in detail.

Logistics

- **Work:** individual.
- **Deadline:** *set by your instructor.*
- **Submission:** one PDF, named `Lastname_Firstname_Module02_Assignment2.pdf`.

Getting access

Everything runs behind a VPN; the target has no public entry points.

1. Open the portal at `https://portal.vuln.gg` and **log in with Discord** (you must be a member of the course server with the student role).
2. Click **Create config**, download `athena.conf`, and import it into the WireGuard client. Activate the tunnel. The portal's VPN card turns **Connected**.
3. Click **New instance**. Your target IP (e.g. `10.10.0.100`) appears immediately; wait until it shows **Ready** (about 3 to 5 minutes) before scanning.
4. Scan that IP (see below).

> **Your instance is deleted automatically 60 minutes after you create it.** The dashboard shows a live countdown. Save your scan output as you go (see the `-oA` tip below). You can start a fresh instance whenever you like; each new one is a clean machine.

Rules of engagement

- **In scope:** only *your own* target IP.
- **Out of scope:** the router / portal (`10.10.0.1`, `portal.vuln.gg`), other students' targets, and anything on the public internet.
- **No** denial-of-service, flooding, or brute-forcing the portal.

The VPN is firewalled so you can only reach your own target. This is not a suggestion, it is enforced. Staying in scope is itself part of the exercise.

1. Scanning the Server

- Use **Nmap** (and other enumeration tools) to scan your target. Your goal is to identify:
  - Open ports.
  - Running services and their versions.
  - Potential entry points based on the services found.
- Document the process in detail: the commands used, the output of your scans, and any notable observations.
- Produce a table summarizing every discovered service, its version, and its port. **The target runs 7 services.** Aim to find and identify all of them.

- One of them does not answer TCP probes at all. If your table has only six rows, re-read the hint below.

Working within the hour, recommended approach:

```
# 1. Fast port discovery across all 65535 ports (seconds, not minutes)
nmap -p- --min-rate 1000 -oA scan-ports <TARGET_IP>

# 2. Service/version detection on just the open ports you found
nmap -sV -p <comma,separated,open,ports> -oA scan-services <TARGET_IP>

# 3. One service speaks UDP only. A full UDP sweep would eat your whole hour,
#    so probe the handful of ports that matter:
sudo nmap -sU --top-ports 20 -oA scan-udp <TARGET_IP>
```

`-oA <name>` saves the results in three formats at once (`.nmap` , `.gnmap` , `.xml`). **Do this.** Your evidence then survives even after the instance is deleted.

2. Enumeration

Scanning tells you *that* a service is there. Enumeration tells you *what is inside it*. Two of the services on the target give up real information to an anonymous client.

File sharing (SMB). Connect without credentials and find out what is shared:

```
smbclient -L //<TARGET_IP> -N              # list the shares
smbclient //<TARGET_IP>/<share> -N -c ls   # list the files in a share
enum4linux -a <TARGET_IP>                  # does both, plus more
```

Network management (SNMP). The service uses a default community string, one of the four or five names every scanner tries first. Find it, then read the system tree:

```
snmpwalk -v 2c -c <community> <TARGET_IP> 1.3.6.1.2.1.1
snmp-check <TARGET_IP>
```

Document for each of the two services:

- The exact commands you ran.
- **SMB:** the share name and the names of the files in it. Read one of them and quote a line.
- **SNMP:** the community string you found, plus the system name, location and contact.
- One sentence per service on why handing this out anonymously is a problem.

3. Analysis

For each discovered service, briefly discuss:

- The potential risks associated with it.
- Any suspicious or unusual service that could indicate a security weakness.
- At least one reference to a public vulnerability database. Cite specific entries from the **NVD** (CVE) where a service or version has known issues.

4. Report Writing

Compile your findings into a well-structured report containing:

- An introduction to the scanning and enumeration task.
- A detailed description of the scanning process (commands + output).
- A summary table of the discovered services and versions.
- Your enumeration findings for SMB and SNMP.
- Your analysis of the services and potential vulnerabilities.
- A conclusion summarizing the key findings.

Use clear, concise, professional language. A starter structure is in `Assignment_2/report-template.md`. You may use it or your own layout, as long as the sections above are covered. Export the finished report to PDF.

Evaluation Criteria

Area	Weight	What earns full marks
Scanning	25%	All 7 services found, each with its correct version and port, UDP included.
Enumeration	25%	Share and file names from SMB, community string and system details from SNMP, with the commands that produced them.
Analysis	25%	A meaningful risk discussion per service, with at least one NVD/CVE reference where applicable.
Report quality	25%	Clear structure (intro, process, table, enumeration, analysis, conclusion), readable, professional.
Bonus	+20%	See below.

Bonus: Finding and Exploiting a Vulnerability

Objective

Earn bonus points by identifying a vulnerability on your target, exploiting it, and documenting the whole process.

Each instance contains a **unique flag** at `/flag` (format `FLAG{...}`). It is different for every student and every new instance, so it cannot be shared or looked up. You have to exploit your own box to read it. Paste the exact flag into your report.

Instructions

1. **Vulnerability identification:**
   - Use Nmap scripts (e.g. `nmap --script vuln`) or another scanner to find a vulnerability in one of the services.
   - Document the commands used and the output showing the vulnerability.
2. **Exploitation:**
   - Research and pick a suitable exploit (e.g. **Metasploit** or a standalone script).
   - Run it and, if successful, read the `/flag` file on the target.
   - Document how you identified the vulnerability, the steps to exploit it, and the tools/commands used.
3. **Write-up:**
   - Add a section titled **"Bonus Points Task: Vulnerability Exploitation."**
   - Include screenshots or logs of the exploitation and of retrieving `/flag` (with the flag visible).

- Explain how the vulnerability could be mitigated or prevented.

Bonus Evaluation Criteria

- **Identification:** effective use of tooling to find a real vulnerability.
- **Exploitation:** clear, reproducible steps, and the correct `/flag` value.
- **Documentation:** clear explanation of identification, exploitation, and mitigation.